

Event Information:

EventID :
51
Event Time :
Feb, 06, 2021, 03:40 PM
Rule :
SOC118 - Internal Port Scan Activity
Level :
Security Analyst
Source Address :
172.16.17.35
Source Hostname :
Katie
File Name :
empty.exe
File Hash :
0a1ca6261fdb9671495be58a5691b21f
File Size :
440 KB
Device Action :
Blocked

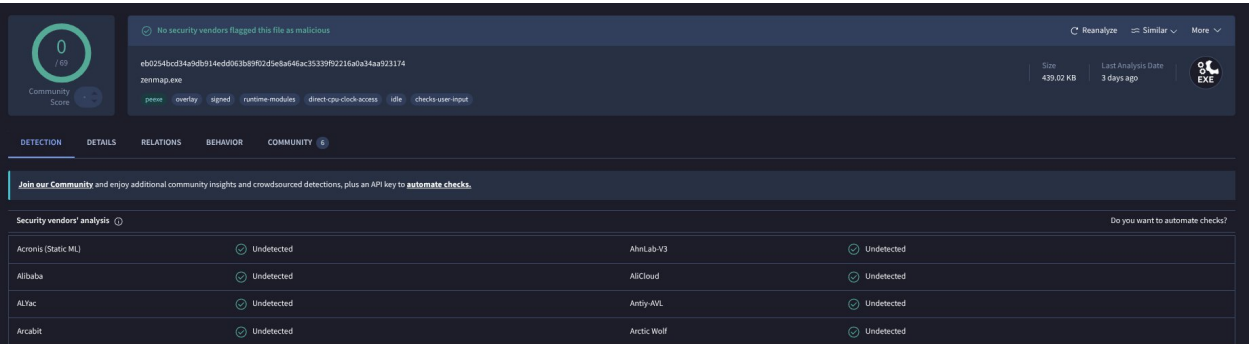
Analysis Steps:

Logs were searched with IP 172.16.17.35 (Katie) as the source in the relevant time-frame yielding 5 events. The port scanning activity cited in the alert can be seen with various uncommon source ports scanning common entry point ports such as 22 (ssh). As indicated by the alert these were all blocked.

The screenshot shows a security log viewer interface. At the top, a search bar contains the text "Source Address contains '172.16.17.35'" and a date filter "2021-02-05". Below the search bar, a status bar indicates "5 events (before Feb, 06, 2021, 03:40 PM UTC)". The main content area displays a table of event details for a single event. The table has two columns: "Field" and "Value". The fields listed are: type (Firewall), source_address (172.16.17.35), source_port (55442), destination_address (172.16.17.45), destination_port (22), time (Feb, 06, 2021, 03:40 PM), Raw Log, and Firewall Action (Blocked). A sidebar on the left lists "INTERESTING FIELDS" with expandable options for type, source_address, source_port, destination_address, destination_port, and raw_log. The bottom of the table indicates "1 row selected".

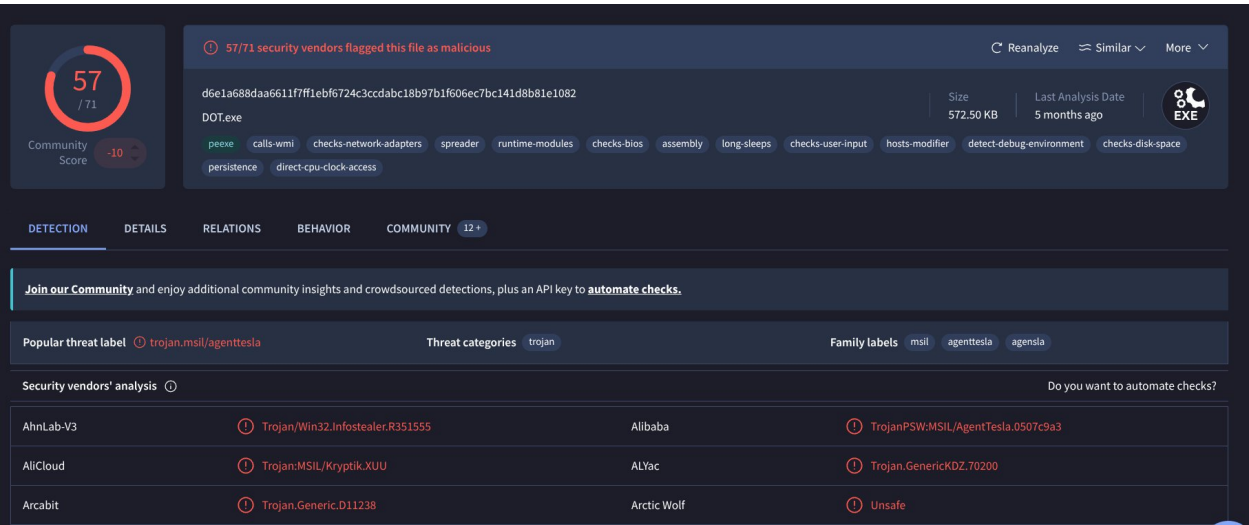
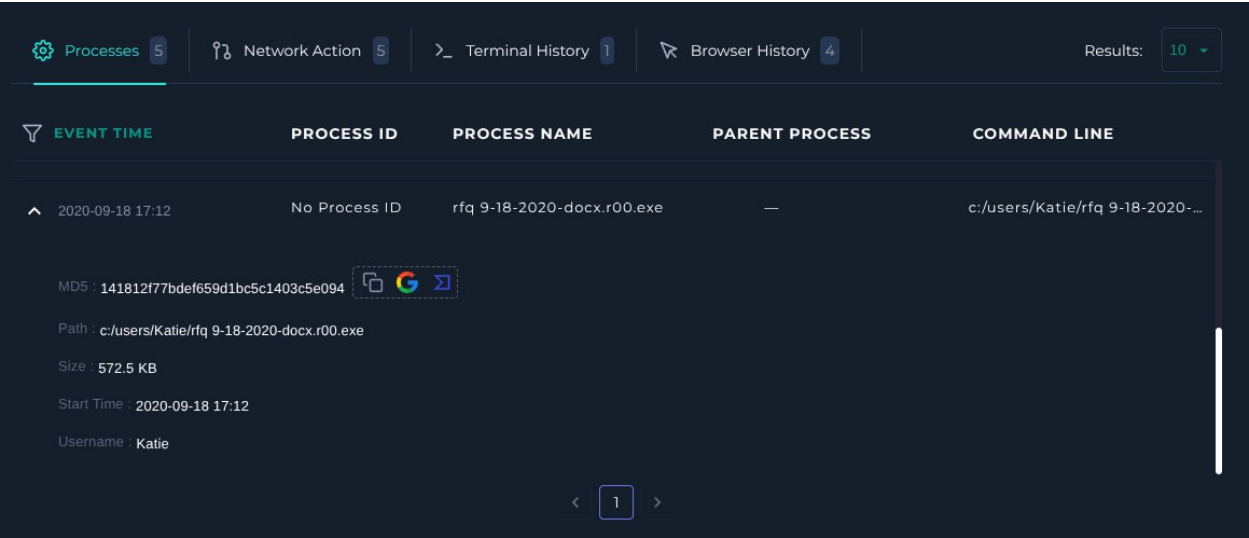
Field	Value
type	Firewall
source_address	172.16.17.35
source_port	55442
destination_address	172.16.17.45
destination_port	22
time	Feb, 06, 2021, 03:40 PM
Raw Log	
Firewall Action	Blocked

When searching the MD5 hash on VirusTotal we can see that Zenmap was being used for port scanning activities which may have been renamed to “empty.exe” as a means of basic obfuscation.



When searching email logs from “Katie”, containing the source IP and around the relevant time-frame nothing can be seen announcing any planned penetration testing so this must be treated as a True Positive and the endpoint should be assumed to be compromised.

When checking the endpoint a suspicious binary can seen to be running. It is quite possible that this is being used as an entry point by an attacker who is attempting lateral movement.



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive alert for internal port scanning activity originating from the host Katie (172[.]16.17.35). While the firewall successfully blocked the port scans, endpoint analysis revealed an active AgentTesla Trojan infection running on the host. The port scanning activity was a clear attempt at lateral movement by the threat actor using a renamed Zenmap executable.

Incident Details

- **Alert Name:** SOC118 - Internal Port Scan Activity
- **Source Host:** Katie (172[.]16.17.35)
- **Flagged File:** empty.exe
- **File Hash:** 0a1ca6261fdb9671495be58a5691b21f
- **Device Action:** Blocked

Analysis and Evidence

- **Network Activity:** Firewall logs show 5 events where the host attempted to scan common entry ports, such as port 22 (SSH), on other internal assets (e.g. 172[.]16.17.45). All attempts were successfully blocked by the firewall.
- **Evasion Tactics:** The executable performing the scans, empty.exe, is a renamed version of Zenmap (a legitimate network mapper), utilised here to obscure the attacker's lateral movement attempts.
- **Endpoint Compromise:** Process analysis on the source host revealed a highly suspicious running binary named rfq 9-18-2020-docx.r00.exe (MD5: 141812f77bdef659d1bc5c1403c5e094), confirming the machine is actively compromised.

Threat Intelligence

- **OSINT (Scanner):** VirusTotal analysis confirms the empty.exe hash belongs to the clean zenmap.exe utility (0/69 detections).
- **OSINT (Payload):** VirusTotal definitively flags the actively running process (rfq 9-18-2020-docx.r00.exe) as malicious (57/71 vendors), specifically identifying it as an AgentTesla Trojan.
- **Internal Correlation:** A review of internal communications confirms no authorised penetration testing is scheduled for this host or time-frame.

Actions Taken

1. Verified the port scanning tool was a renamed Zenmap executable.
2. Investigated the source endpoint and discovered an active AgentTesla malware infection.
3. Declared the alert a True Positive representing attempted lateral movement from a compromised host and escalated.

Let's Defend Result

SOC118 - Internal Port Scan Activity

True Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Analyze Malware (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)

As with an alert I tackled previously involving Nmap, Letsdefend expects you to select the option indicating that Zenmap is malware which I do not think is strictly fair. Zenmap can just be used for malicious purposes similar to how applications like Powershell are abused, but it is a legitimate tool and not malware.